

Aula 2 (Módulo 13) — Aplicando o Framework Completo: Tática

→ Técnica → Procedimento → Evidência → Detecção →

Resposta

Fechando o módulo aplicando a cadeia completa a **dois cenários** que já investigamos antes (Módulo 10) — agora com a estrutura formal do ATT&CK amarrando tudo.

O template

TÁTICA	→ o objetivo do atacante nessa etapa
TÉCNICA	→ o método específico (com ID oficial)
PROCEDIMENTO	→ como foi implementado NESSE caso específico
EVIDÊNCIA	→ o que ficou registrado (logs, telemetria)
DETECÇÃO	→ a regra/lógica que identificaria isso
RESPOSTA	→ a ação de contenção/remediação

Aplicação 1 — Cenário 1 e 4 do Módulo 10 (revisão)

Lembra do PowerShell suspeito filho do Outlook, seguido da criação de uma Run key? Vamos decompor em **duas** técnicas encadeadas:

Parte A — Execução

TÁTICA: Execution

TÉCNICA: T1059.001 – Command and Scripting Interpreter: PowerShell

PROCEDIMENTO: powershell.exe -nop -w hidden -enc <base64>, filho de outlook.exe, provavelmente disparado por um anexo/link malicioso (T1566 – Phishing, tática Initial Access, seria a etapa ANTERIOR a esta na cadeia completa)

EVIDÊNCIA: Sysmon Event ID 1 (ParentImage=outlook.exe, Image=powershell.exe, CommandLine com -enc); Windows Event ID 4688 (se auditoria habilitada); Event ID 4104 (PowerShell Script Block Logging, revelando o comando decodificado – Módulo 02, Aula 5)

DETECÇÃO: SE ParentImage em (outlook.exe, winword.exe, excel.exe) E Image em (powershell.exe, cmd.exe) ENTÃO alertar Severidade Alta

RESPOSTA: Isolar o host (capacidade de EDR, Módulo 10); decodificar o Base64 para entender o payload completo; revisar o e-mail/anexo de origem; verificar se outros hosts receberam o mesmo e-mail (escopo do incidente, Módulo 15)

Parte B — Persistência

TÁTICA: Persistence

TÉCNICA: T1547.001 – Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder

PROCEDIMENTO: Chave criada em HKCU\...\CurrentVersion\Run, nome "WindowsUpdateHelper" (disfarçado), apontando para svhost.exe (typosquatting do nome do processo legítimo svchost.exe) em %APPDATA%

EVIDÊNCIA: Sysmon Event ID 13 (Registry Value Set) – TargetObject contendo "CurrentVersion\Run"; Sysmon Event ID 11 (File Create) registrando a criação do svhost.exe em %APPDATA%

DETECÇÃO: SE TargetObject contém "CurrentVersion\Run" ENTÃO alertar para revisão (a maioria é legítima, mas toda escrita merece checagem – como já vimos no Módulo 11)

RESPOSTA: Remover a chave de Registry e o arquivo malicioso; verificar se o processo malicioso já executou a partir dessa persistência (reboot já aconteceu desde a criação?); documentar como parte do MESMO incidente da Parte A (não é um evento isolado)

Observação importante: as Partes A e B são **duas técnicas diferentes**, de **duas táticas diferentes** (Execution e Persistence), mas fazem parte de **um único incidente**. Isso é normal — um ataque real quase sempre encadeia múltiplas

técnicas, cada uma cumprindo um objetivo diferente na progressão do ataque. Reconstituir essa cadeia completa é exatamente o trabalho de Incident Response (Módulo 15).

Aplicação 2 — Cenário 3 do Módulo 10 (revisão)

Lembra do `sqlservr.exe → cmd.exe → net.exe user` ?

TÁTICA:	Discovery
TÉCNICA:	T1087 – Account Discovery
PROCEDIMENTO:	net.exe user, executado via cmd.exe, filho de um processo de banco de dados comprometido (sqlservr.exe)
EVIDÊNCIA:	Sysmon Event ID 1, mostrando a cadeia completa sqlservr.exe → cmd.exe → net.exe, com a command line "user" como argumento
DETECÇÃO:	SE ParentImage = sqlservr.exe E Image em (cmd.exe, powershell.exe) ENTÃO alertar Severidade Crítica (processo de banco de dados não deveria gerar shell)
RESPOSTA:	Isolar o servidor; revisar logs do SQL Server para encontrar a query/conexão de origem (provável exploração via T1190 – Exploit Public-Facing Application, ou abuso de funcionalidade como xp_cmdshell); patchear a vulnerabilidade/configuração explorada

O padrão que se repete

Nenhum incidente real é "uma técnica só". É sempre uma CADEIA:
Initial Access → Execution → (Discovery/Privilege Escalation) →
Persistence → (Lateral Movement) → (Collection) → Exfiltration/Impact

Cada elo da cadeia:

- tem seu próprio ID de técnica
- gera sua própria evidência
- pode (e deve) ter sua própria detecção
- exige sua própria resposta – mas todas fazem parte do MESMO caso

Por que isso importa para sua carreira

Saber **nomear** o que você está vendo usando os IDs oficiais do ATT&CK é uma habilidade prática, não só acadêmica: relatórios de incidente profissionais citam técnicas por ID; ferramentas de SIEM/EDR comerciais já vêm com regras mapeadas para técnicas ATT&CK; vagas de Detection Engineering e Threat Hunting frequentemente pedem, explicitamente, "cobertura de matriz ATT&CK" como métrica de trabalho. Vamos usar essa mesma estrutura, de forma ainda mais aplicada, no Módulo 14 (Threat Hunting) e no Módulo 21 (Detection Engineering).

Exercício prático

Escolha **um** dos cinco cenários do Módulo 10 que ainda não decomposemos aqui (Cenário 2 — execução de binário desconhecido, ou Cenário 5 — conexão suspeita de exfiltração) e monte você mesmo a cadeia completa: Tática → Técnica (busque o ID real em attack.mitre.org) → Procedimento → Evidência → Detecção → Resposta.

Recapitulando o Módulo 13

- O framework completo (Tática → Técnica → Procedimento → Evidência → Detecção → Resposta) é a forma estruturada de documentar **qualquer** achado de segurança de forma profissional e comparável.
- Um incidente real quase sempre encadeia múltiplas técnicas de múltiplas táticas — nunca é "uma coisa isolada".
- Nomear tecnicamente com IDs oficiais do ATT&CK é uma habilidade prática esperada em vagas de Blue Team, não só teoria.

Módulo 13 concluído. 🎉

Próximo módulo

Módulo 14 — Threat Hunting: usando essa mesma estrutura de tática/técnica para formular **hipóteses** e caçar ameaças que **nenhum alerta** ainda detectou — indo além de reagir a alertas.

Fontes recomendadas

- **MITRE ATT&CK — "Understanding and Using ATT&CK":** guia oficial de como aplicar o framework em processos reais de segurança. <https://attack.mitre.org/resources/getting-started/>
- **Center for Threat-Informed Defense (MITRE Engenuity):** projetos oficiais derivados do ATT&CK, incluindo mapeamento de detecções e métricas de cobertura. <https://ctid.mitre.org/>